OpenID Connect (OIDC) is a protocol that enables an application (called the *Client*) to verify the identity of a user based on the authentication performed by a trusted party (called an *Authorization Server*) and retrieve the user profile information. The authorization server informs the Client application about the result of the authentication step via an *ID Token*.

OIDC is an identity layer on top of OAuth2, an authorization framework that solves the problem of delegating access using tokens for authorization but doesn't deal with authentication. As you know, authorization can only happen after authentication. That's why I decided to cover OIDC first; OAuth2 will be further explored in the next chapter. This is not the typical way of covering those subjects, but I think it makes sense when designing an access control system like we're doing for Polar Bookshop.

NOTE This book will only cover some essential aspects of OAuth2 and OIDC. If you're interested in learning more about them, Manning has a couple of books in its catalog on the subject: *OAuth 2 in Action* by Justin Richer and Antonio Sanso (Manning, 2017) and *OpenID Connect in Action* by Prabath Siriwardena (Manning, 2022).

When it comes to handling user authentication, we can identify three main actors in the OAuth2 framework that are used by the OIDC protocol:

- *Authorization Server*—The entity responsible for authenticating users and issuing tokens. In Polar Bookshop, this will be Keycloak.
- *User*—Also called the *Resource Owner*, this is the human logging in with the Authorization Server to get authenticated access to the Client application. In Polar Bookshop, it's either a customer or an employee.